

← Go back



"Exposed Drupal Installer and JSON:API User Enumeration on [REDACTED]"

Submitted 5 months ago • Last activity 4 months ago

Submission details

Revisions 1

ID	f5777f49-8531-4986-88f7-122ec3472518
Submitted	29 Oct 2025 06:20:49 GMT+0
Target Location	[REDACTED]
Target category	Web App
VRT	Other
Priority	P2
Bug URL	https://[REDACTED]/core/install.php
Description	Administrative portals for an application allow Admins to log in and modify how the application runs and the content it serves. This can include adding, removing, updating, or creating new content, account provisioning, data manipulation, and other configuration changes. An attacker is able to identify an exposed portal and can then brute force credentials. If they successfully log in, they can access the backend interface and carry out activities within it with Admin privileges. Business Impact Exposed portals can lead to indirect financial loss due to the attacker's ability to modify, remove or create data within the admin portal. It can also cause reputational damage for the business due to a loss in confidence and trust by users. Steps to Reproduce 1. Use a browser to navigate to the portal via the URL: <code>https://1800respect.org.au/core/install.php</code> 2. The following are the functionalities of the admin portal: 3. Drupal Installer (P3): Public access to <code>/core/install.php</code> exposes an administrative interface. If protections fail, this could allow re-installation or misconfiguration of the production site. <pre>[[value]]</pre> 1. Execute <code>{{action}}</code> on the admin portal: <code>curl -IL \ -H "X-Bug-Bounty: BugCrowd-RahadRabbani" \ https://[REDACTED]/core/install.php</code> <pre>HTTP/2 301 date: Wed, 29 Oct 2025 05:54:35 GMT content-type: text/html location: https://[REDACTED]/core/install.php tracereponse: 00-1872e08725c5aebc7b791cb356c8dd2b-b8ef1aed73912aef9-01 cf-cache-status: DYNAMIC server: cloudflare cf-ray: 99606b47a98683321-SIN HTTP/2 200 date: Wed, 29 Oct 2025 05:54:36 GMT content-type: text/html; charset=UTF-8 cache-control: must-revalidate, no-cache, private expires: Sun, 19 Nov 1978 05:00:00 GMT last-modified: Wed, 29 Oct 2025 05:54:36 +0000 tracereponse: 00-1872e087510c6798425b14e14e6ae9b8-deae80eefea3d762-01 cf-cache-status: DYNAMIC server: cloudflare cf-ray: 99606b4d2dca83321-SIN \$ curl -IL \ -H "X-Bug-Bounty: BugCrowd-RahadRabbani" \ https://[REDACTED]/core/install.php HTTP/2 301 date: Wed, 29 Oct 2025 05:56:40 GMT content-type: text/html location: https://[REDACTED]/core/install.php tracereponse: 00-1872e0a435d29f1cfb7aef6d76425e7-abcd5a992d8a39f8-01 x-debug-info: c9y28y9mWz3j9dQw= x-platform-cluster: 3621j7qg9okaw-main-bvxa61 x-platform-router: mapm6wz12ojd2tj6gna2d54 cf-cache-status: DYNAMIC server: cloudflare cf-ray: 9960635ea5331b-SIN HTTP/2 200 date: Wed, 29 Oct 2025 05:56:41 GMT content-type: text/html; charset=UTF-8 cache-control: must-revalidate, no-cache, private expires: Sun, 19 Nov 1978 05:00:00 GMT last-modified: Wed, 29 Oct 2025 05:56:40 +0000 tracereponse: 00-1872e0a45719f97ba1297d181a1a14-6a3e6fd8e5d9b7f-01 x-debug-info: c9y28y9mWz3j9dQw= x-platform-cache: MISS x-platform-cluster: 3621j7qg9okaw-main-bvxa61 x-platform-processor: kettm6z1baaw1579k1p6xyxy x-platform-router: mapm6wz12ojd2tj6gna2d54 cf-cache-status: DYNAMIC server: cloudflare cf-ray: 9960635ec13c92-SIN</pre>

Status

Resolved

This submission has been fixed!

Reward

VRT version

1.17

Engagement

Submitted to

🧑 [REDACTED] VDP

Closed on

13 Nov 2025

CrowdStream visibility

Choose to show your details with this submission in CrowdStream when accepted.

Please note: your username will always be shown with your submission if it is disclosed.

🔓 Show username

🔓 Show reward

🔒 Please note: This engagement does not currently disclose submission activity in CrowdStream.

Disclosure policy

Please note: This engagement does **not allow** disclosure. You may not release information about vulnerabilities found in this engagement to the public.

Need help?

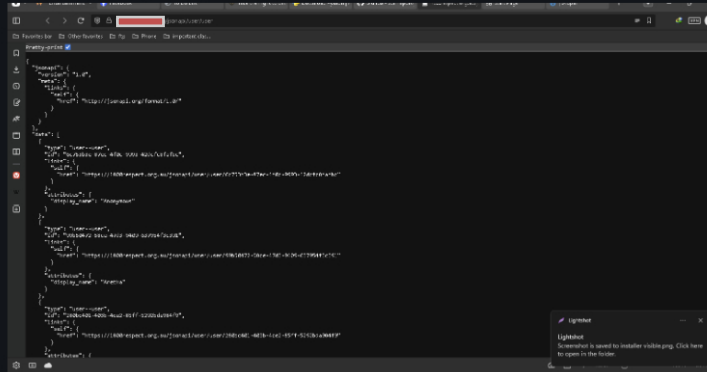
Issues with a submission? Please visit Bugcrowd Support and create a support ticket.

1. JSON:API User Enumeration

- VRT: Sensitive Data Exposure → User Enumeration
- URL: [https://\[redacted\]/jsonapi/user/user](https://[redacted]/jsonapi/user/user)
- Impact: Leaks valid user accounts and IDs, enabling targeted attacks.

Unauthenticated access to the `/jsonapi/user/user` endpoint allows an attacker to enumerate valid user accounts. This can lead to:

- Reconnaissance for targeted attacks – attackers can identify usernames, IDs, or roles to craft phishing or credential-stuffing campaigns.
- Privilege escalation attempts – knowing which accounts exist (especially admin or staff accounts) helps attackers focus brute-force or password spraying.
- Information disclosure – even seemingly harmless metadata (user IDs, display names, timestamps) can be leveraged to map the application's structure and relationships.



{{screenshot}}

Files attached

- Image-2025-10-29T05:56:52.454Z.png (39.1 KB)
- installer%20visible.png (35.1 KB)
- user%20names%20visible%20with%20id.png (40.6 KB)

Activity

- rahat_rab** created the submission
5 months ago (29 Oct 2025 06:20:49 GMT+0)
- Bugcrowd** created a blocker on **[redacted] Ltd** to respond to comments
5 months ago (29 Oct 2025 21:55:45 GMT+0)
- Bugcrowd Staff** sent a private message to **Customer**
5 months ago (29 Oct 2025 21:55:46 GMT+0)
- Bugcrowd** sent a message
5 months ago (29 Oct 2025 21:55:56 GMT+0)

Hi rahat_rab,

Thank you for your efforts. We are checking the report further with the program's security team and will update you.

More to come!

Best regards,

Bugcrowd

- Bugcrowd** updated VRT to **Other**
5 months ago (29 Oct 2025 21:56:05 GMT+0)
- Customer** sent a private message to **Bugcrowd Staff**
5 months ago (30 Oct 2025 22:42:35 GMT+0)
- [redacted]** resolved a blocker for **[redacted] Ltd** by responding to comments
5 months ago (30 Oct 2025 22:42:36 GMT+0)
- [redacted]** created a blocker on **Bugcrowd Operations** to respond to comments
5 months ago (30 Oct 2025 22:42:46 GMT+0)
- Bugcrowd** changed the severity to **P2**
5 months ago (01 Nov 2025 17:39:23 GMT+0)
- Bugcrowd** changed the state to **Triaged**
5 months ago (01 Nov 2025 17:39:24 GMT+0)
- Bugcrowd Staff** sent a private message to **Customer**
5 months ago (01 Nov 2025 17:39:42 GMT+0)
- Bugcrowd** resolved a blocker for **Bugcrowd Operations** by responding to comments
5 months ago (01 Nov 2025 17:39:43 GMT+0)
- Bugcrowd** sent a message
5 months ago (01 Nov 2025 17:39:54 GMT+0)

Hi rahat_rab,

Thank you for your patience. We have marked this submission as 'Triaged' so that the customer team can have a closer look at your submission.

Note that the final severity, and status of this submission are subject to change as this receives a further review from the team working on this program. We appreciate your time, and look forward to more submissions from you in the future!

Best regards,

Bugcrowd



rahat_rab sent a message

5 months ago (03 Nov 2025 17:30:28 GMT+0)

thank you



rahat_rab submitted a response request from Bugcrowd with reason: Reward

5 months ago (06 Nov 2025 13:08:30 GMT+0)

My estimated date was 3 nov but its gone past that. I m new and this is my first report so out of curiosity how long does it usually take for a complete review of submissions and pay to be added to account. thank you



REDACTED sent a message

5 months ago (06 Nov 2025 13:10:54 GMT+0) • Edited 5 months ago

Hi rahat_rab,

We would like to clarify that VDP programs on Bugcrowd do not offer monetary rewards or [points](#) for submissions.

The timeline for the fix to be applied and confirmed entirely depends on the customer, we can't provide you with an estimation in that regard.

Best regards,

bugcrowd



REDACTED marked the response request as resolved

5 months ago (06 Nov 2025 13:10:55 GMT+0)



REDACTED sent a message

4 months ago (13 Nov 2025 05:43:50 GMT+0)

Hi Rahat_Rab,

Welcome to the program!

Thanks for this finding — the team was able to restrict the leaked information.



REDACTED changed the state to **Unresolved**

4 months ago (13 Nov 2025 05:44:00 GMT+0)



REDACTED changed the state to **Resolved**

4 months ago (13 Nov 2025 22:49:48 GMT+0)



Bugcrowd has marked your response request as resolved

Your request has received a response and is resolved. You are eligible to submit a final request from the customer or Bugcrowd.

[Read more about requesting a response in our Bugcrowd documentation.](#)

This will be your final request, be sure to consider the resolution of your previous request and include as much information as possible.

Submit final request 2 of 2 available



Send a message

To

Everyone

B

I

99

<>

🔗

📄

📋

📌

Write

Preview

Your message to everyone here...

Embed images by dragging & dropping, **selecting**, or pasting them.



Add attachments

You can attach up to 20 files. Please keep individual upload size under 400MiB.

You can embed attachments (.jpg/.gif/.png, smaller than 5MB) into the Markdown fields. You can copy the embed code using the "Copy as Markdown" button.

Send message

[Terms & Conditions](#) [Privacy Policy](#) [Security](#) [Do Not Sell My Information](#)

bugcrowd Copyright © 2014 – 2026 Bugcrowd, Inc. All rights reserved.

[Docs](#) [FAQ](#) [Resources](#) [Blog](#) [Contact](#) [Get Help](#)

Support